

Part 1 — Crisis Assessment

Executive summary

The platform runs multiple Java Spring Boot microservices. Current deployment failures (~70%) are caused by manual builds, hardcoded secrets, lack of automated testing, and inconsistent environment configuration. Aim: within 30 days, achieve >90% automated deployment success, 15-minute rollback time, and full audit trails.

Root Cause Analysis (Top 5)

1. **Hardcoded secrets & config in Dockerfiles / manifests.**
 - Risk: secret leakage, environment differences, inability to rotate. Causes prod failures when configs differ.
2. **Manual, inconsistent builds and image tagging (service:latest).**
 - Risk: drift across envs; unpredictable runtime behavior; causes runtime failures.
3. **No automated testing (unit/integration/contract).**
 - Risk: regressions reach higher environments; causes functional failures post-deploy.
4. **Manual DB migrations with no snapshots/dry-run.**
 - Risk: destructive schema changes; requires manual recovery; causes data-loss & deployment aborts.
5. **No deployment coordination & missing health checks.**
 - Risk: dependent services deployed in wrong order and unhealthy pods receive traffic.

Prioritization (0–30 days)

- **Immediate (0–7d):** stop hardcoding secrets; centralize secrets; add readiness/liveness probes; add simple CI that builds & unit-tests.
- **Week 2 (7–14d):** implement image scanning (Trivy), SCA (Snyk), static analysis (SonarQube), and secret scanning (gitLeaks). Add smoke tests in pipeline.
- **Week 3 (14–21d):** implement Flyway DB migrations with pre-snapshot; automate CI→Dev→UAT flows; configure ArgoCD for GitOps.
- **Week 4 (21–30d):** implement production rollout (canary/blue-green), configure monitoring (Prometheus, OpenSearch, Jaeger) and automated rollback on metric thresholds.

30-Day Emergency Plan (summary of actions)

- Enforce branch protection + pipeline quality gates.
- Build reproducible images in CI using overlay Dockerfiles in implementation/docker/.
- Use GitHub Actions for CI; push images to ECR / GHCR.
- Use ArgoCD with manifests from implementation/k8s/<env>/.
- Implement Flyway migration job with pre-migration RDS snapshot for prod.
- Implement automated smoke tests and alerts (Slack / PagerDuty).
- Run a rollback and DR rehearsal before making prod changes.

Rollback within 15 minutes

- Helm/ArgoCD rollback for deployment artifacts.
- RDS snapshot restore plan for DB if migration broken; snapshot made immediately before prod migration step.
- Pre-scripted commands in implementation/ci-cd/scripts/rollback.sh. Practice and time the runbook.

Risk assessment

- **Compliance:** No audit trail — mitigation: audit-service event emission at each deploy; store pipeline run metadata.
- **Security:** Hardcoded secrets — mitigation: Secrets Manager / Vault + ExternalSecrets.
- **Operational:** Skill gaps — mitigation: runbooks, pairing, time-boxed approvals.

Team & training

- Quick training sessions for developers on CI, GitOps, and feature flags.
- SRE runbook drills to practice rollback and DR scenario.